Software Engineering

CSC648/848

Week 7 Summary

1. What is Coding/Programing Style?

   Set of rules or guidelines used when writing the source code for a computer program (Software)

2. What are the elements of coding style?
   1. *Naming Conventions (variables, functions, classes)*
   2. *File naming and Organization*
   3. *Formatting*
   4. *Comments*
   5. *Documentation*

3. What are the benefits of good coding style?

   Easier: Maintenance, Testing, Optimization, and Portability.

4. What are some of the best practices of coding style for Security?
   1. *Use code & architecture reviews*
   2. *Check inputs*
   3. *Ensure proper transmission and management of Passwords*
   4. *Use secure internet protocols*
   5. *Check buffer size*
   6. *Prevent injection of SQL code into forms*

Henry
VILLAR

SECURITY ENGINEERING

Software Systems that can resist malicious attacks

Important

Security SW Engineering

- Security engineering focuses on how to develop and maintain software systems that can resist malicious attacks intended to damage a computer-based system or its data.

ANATOMY OF AN ATTACK

Objective and Topics

Objective: Cover SE processes and practices related to creating secure SW systems.

- Security concepts, terminology
- Security Requirement and Specification Process
- Security Risk management
- Design and coding practices for security
- Some practical advices
  - Security certificates and HTTPS for WWW sites
  - Securing forms input

Important

Issues

- As in all complex systems security management relates to

- ❑ People
- ❑ Process, policies
- ❑ Technology

Check current press

- Frequent coverage of security breaches (often simply unprotected PW)
- Latest:
  - https://www.splunk.com/en_us/cyber-security/solarwinds-cyberattack-response.html
  - https://healthitsecurity.com/news/white-house-solarwinds-hack-impacted-9-fed-agencies-100-entities
- https://cybersecuritynews.com/cyber-security-news-letter-october/
- https://www.cisa.gov/topics/cyber-threats-and-advisories
- Good career path

White House: SolarWinds Hack Impacted 9 Fed Agencies, 100 Entities

A White House press briefing on Wednesday confirmed the SolarWinds Orion hack impacted nine federal agencies and 100 private sector entities; the final tally is expected to increase.

System layers where security may be compromised

Application	
Reusable components and libraries	
Middleware	
Database management	
Generic, shared applications (browsers, e--mail, etc)	
Operating System	
Network	Computer hardware

Important

Security concepts/terminology

Term	Definition
Asset	Something of value which has to be protected. The asset may be the software system itself or data used by that system.
Attack	An exploitation of a system's vulnerability. Generally, this is from outside the system and is a deliberate attempt to cause some damage.
Control	A protective measure that reduces a system's vulnerability. Encryption is an example of a control that reduces a vulnerability of a weak access control system
Exposure	Possible loss or harm to a computing system. This can be loss or damage to data, or can be a loss of time and effort if recovery is necessary after a security breach.
Threat	Circumstances that have potential to cause loss or harm. You can think of these as a system vulnerability that is subjected to an attack.
Vulnerability	A weakness in a computer-based system that may be exploited to cause loss or harm.

13.2 For the Mentcare system, suggest an example of an asset, an exposure, a vulnerability, an attack, a threat and a control, in addition to those discussed in this chapter.

Asset	Local database stored on nurses laptop or clinic PC
Exposure	Moderate. Loss of consultation records. Clinical consequences possible if
Vulnerability	Nurse or doctor leave consultation with patient but leave themselves logged into system
Attack	Patient accesses unattended system
Threat	Patient deletes or corrupts patient records held in local database.
Control	Log all actions and support 'undo' of log actions. Require password to open individual patient records.

Security

- The security of a system is a system property that reflects the system's ability to protect itself from accidental or deliberate external attack.
- Security is essential as most systems are networked so that external access to the system through the Internet is possible.
- Security is an essential pre-requisite for availability, reliability and safety.

Security dimensions - Types of **Threats**

- *Confidentiality*
  - Information in a system may be **disclosed or made accessible** to people or programs that are not authorized to have access to that information.
- *Integrity*
  - Information in a system may be **damaged or corrupted** making it unusual or unreliable.
- *Availability*
  - Access to a system or its data that is normally available may not be possible.

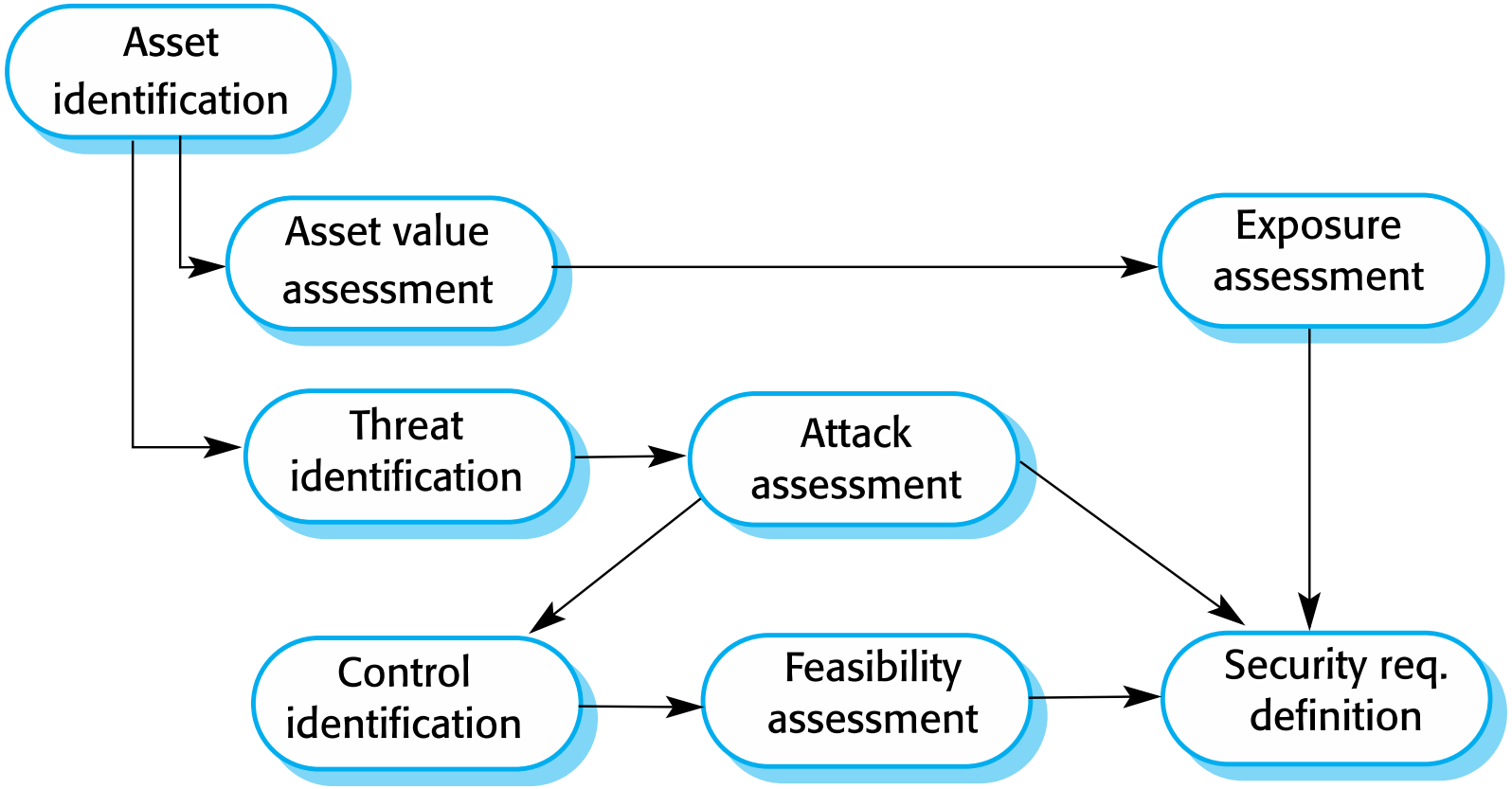
Security Assurance - **Controls** against threats

- Vulnerability avoidance
  - The system is designed so that vulnerabilities **do not occur.** For example, if there is no external network connection then external attack is impossible
- Attack detection and elimination
  - The system is designed so that attacks on vulnerabilities are **detected** and neutralised before they result in an exposure. For example, virus checkers find and remove viruses before they infect a system
- Exposure limitation and recovery
  - The system is designed so that the adverse consequences of a successful attack are **minimised**. For example, a backup policy allows damaged information to be restored

Security requirements and specification process

The preliminary risk assessment process for security requirements

Important



Security Risk Management

Important

Overview

- Assessing the possible losses that might ensue from attacks on the system
- Balancing these losses against the costs of security procedures that may reduce these losses.
- Risk management should be driven by an organizational security policy.
- Risk management involves
  - Preliminary risk assessment
  - Life cycle risk assessment

Asset Analysis: Example

Asset	Value	Exposure
The information system	High	High, Financial loss – losing customers, restoring system, communication
The user database	High	High, Financial loss, harm to users
An individual user record	Normally low other than high profile patients	Direct loss is low, loss of reputation

Acknowledged use of SE book by Sommerville (2006), 8e

Threat and Control Analysis: Example

Threat	Probability	Control	Feasibility
Unauthorized user gains access to confidential data	High	1. Require users to authenticate themselves. 2. Track system usage	High cost, user resistance. Simple to implement, supports recovery.
Unauthorized user makes system unavailable	Low	Allow system management from known physical location that are secure	Low cost. Attention to distribution of keys.

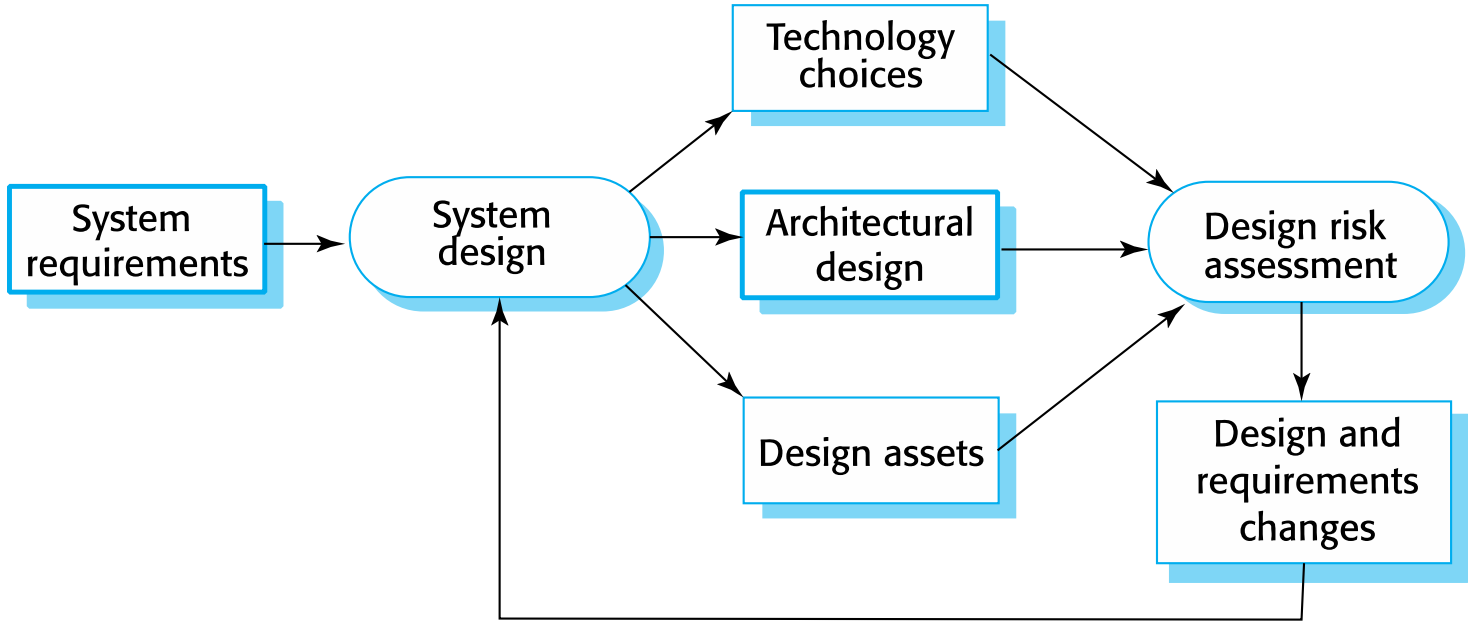
Acknowledged use of SE book by Sommerville (2006), 8e

Security Design and Coding Guidelines

Secure systems design

- **Security should be designed into a system** – it is very difficult to make an insecure system secure after it has been designed or implemented
- **Architectural design**
  - how do architectural design decisions affect the security of a system?
- **Good practice**
  - what is accepted good practice when designing secure systems?

Design and risk assessment

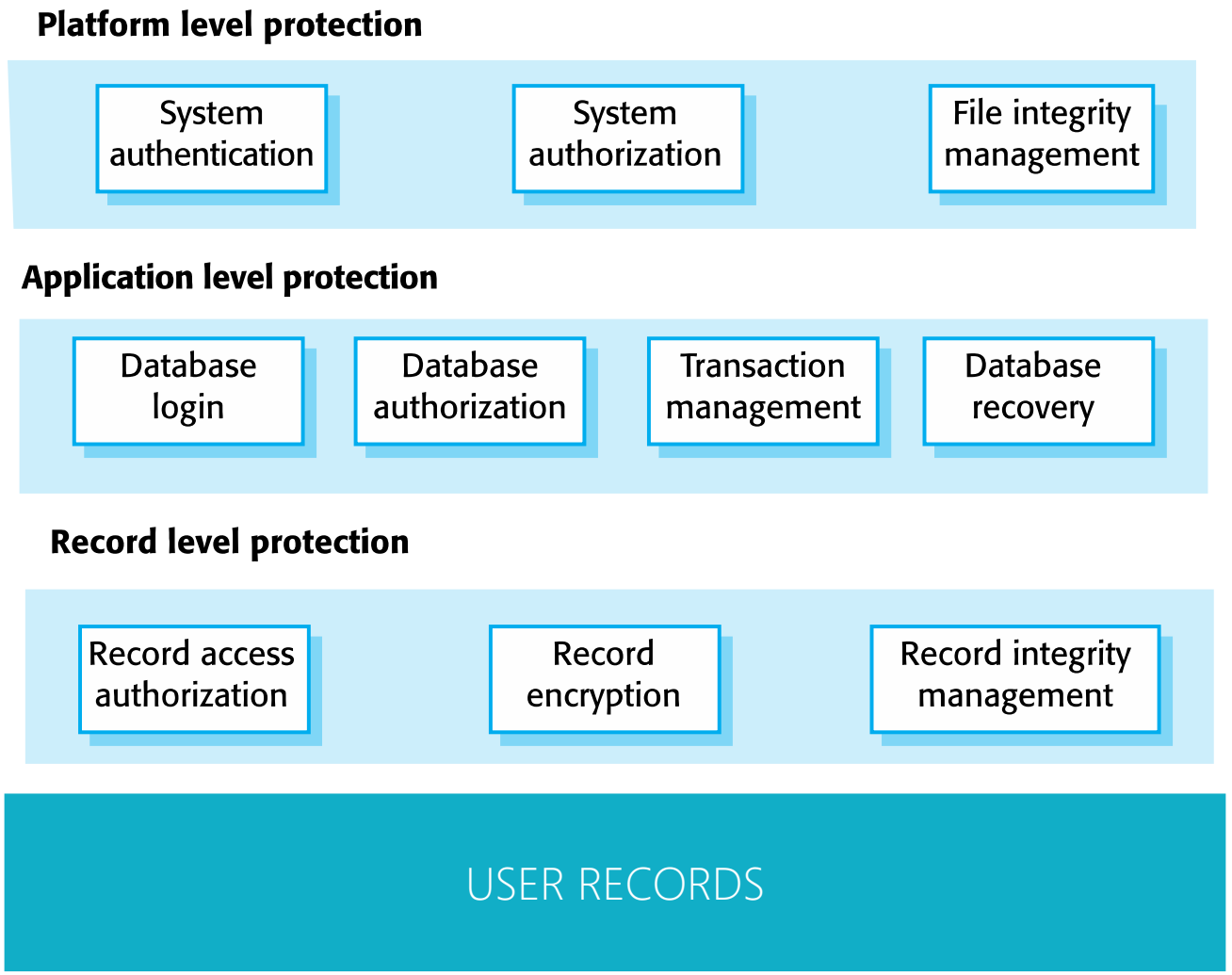


Architectural Design

- Protection
  - How should the system be organized so that critical assets can be protected against external attack?
- Distribution
  - How should system assets be distributed so that the effects of a successful attack are minimized?

Important

A layered protection architecture



Important

Other Issues - Process

- Access management
- Password management
- Physical rooms security
- People issues and HR
- Auditing SW – usually using *white box* analysis (code inspection)

Important

Best Practices Coding Style for Security

- Ensure and enforce proper coding practices – use code and architecture reviews
- **Check inputs** and allow only valid ones
- Ensure proper transmission and management of **passwords**
- Use **secure internet protocols**
- Check **buffer size** – make sure no attack can be done by sending longer data streams
- **Prevent injection of SQL** code into the forms
- Check uploaded content for **executables**
- Virus check all **uploaded content**

Web and Internet security – some resources and examples

- http://www.cisecurity.org/
- http://msdn.microsoft.com/en-us/library/ff648647.aspx
- http://en.wikipedia.org/wiki/Web_application_security
  - "The majority of web application attacks occur through cross-site scripting (XSS) and SQL injection attacks[6] which typically result from flawed coding, and failure to sanitize input to and output from the web application."

Use and setting of HTTPS for your WWW site

- HTTPS – secure protocol
- Use for communicating confidential stuff (pw, login, registration, account and credit card data…)
- Easy to set up but requires purchase of sec. certificate
- Good brief tutorial
  - http://www.howto-expert.com/how-to-get-https-setting-up-ssl-on-your-website/

Forms and security

- Most common WWW security attacks – forms used most often as a venue of the attack

- Cross site scripting
  - https://excess-xss.com/
- SQL Injection
  - https://www.w3schools.com/sql/sql_injection.asp
  - https://en.wikipedia.org/wiki/SQL_injection

Forms and security

- Hence, follow best SE practices for forms security (and other types of security issues)
- One of the fist places to start is validation of form inputs ➔ plenty of tools and coder and APIs available e.g.
  - https://1000hz.github.io/bootstrap-validator/
  - https://help.formassembly.com/help/best-practices-in-web-form-security

Mobile apps security best practces

- https://www.tripwire.com/state-of-security/security-awareness/top-mobile-app-security-best-practices-developers/
- https://www.newgenapps.com/blog/10-biggest-risks-to-mobile-apps-security
- https://www.ipraxa.com/blog/mobile-app-security-best-practices/

Team Project Time

- Milestone 3 Review of functionality, UI, SW and planning for final product delivery. Objectives and Overview:
    1. Define exactly what product you are delivering
    2. Ensure software development is on track
    3. Provide feedback on all major UI screens and functionality
    4. Check the code and software architecture
    5. Check all algorithms
    6. Identify and address all technical risks
    7. Ensure effective teamwork
    8. Ensure software development is effective
  - *Part 1*: Each team meets with Prof. Villar Review of functionality, UI and general project status. 20-30 minutes. Checklist for this part is in Appendix I. The feedback as well as finalized P1 list MUST be recorded using template (or its modification) as in Appendix I. You will submit it (summary Document) with M5 folder.
    - *UI and functionality feedback (P1 functions only)*
    - *Brief review of code, github, database etc.*
    - *Project status – be ready to verbally explain status of the issues below*
    - *List of P1 features committed for delivery agreed at M3 review meeting*
  - *Part 2*: SW review off-line. Architecture, Code, github, team account, database and general SW and code review will be done off-line.

  - NOTE: The M3 SUMMARY document must be part of the M5 final documentation

Final Project Main Functions

- <u>Web App: Voting Guide with AI+</u>

1. **Search & Filter** by state, political party and issues/policies.
2. **Enter** official information (political parties, voter registration, polling location, voting process, etc.)
3. Site **Registration** (College Students, General public, Officials, Admin, etc.).
4. **Rate** candidates.
5. Search results may be displayed **using maps**
6. **AI capabilities** is a plus.

Two entrepreneurs, SFSU alumni, decided to create a start-up comprising of a team of about 6+ students to develop a web-based service to help USA college students and general public to identify *county, state, and federal*/national **candidates** running for public offices and their respective *policies*, and *background*. The web application will allow officials from the different **political parties** to enter the corresponding official information, and the **Elections office** to enter information about voter registration, polling locations, and voting process. College students and general public should be able to search by state, political party and issues/policies so results can list the corresponding data, and at the same time; user (student and general public) can enter their issues of interest and the AI chatbot can assist them with mapping what candidates are aligned with the user interest. This application is targeting three primary audiences: (1) College Students, (2) General Public, and (3) Officials from the political parties and election office. Students and general public users should be able to rate candidates. Officials from political parties and election office may need to be registered to use all the functionality of the application. General users may access to limited search capabilities and application functionality. Search results may display maps.

Thank You